Figure 1.6 An example dataflow diagram, showing processes, data stores and the flow of data between them. Trust boundaries are marked with dashed lines. Internal processes are marked with rounded rectangles, while external entities use squared ends. Note that we include both the database management system (DBMS) process and its data files as separate entities.

IDENTIFYING THREATS

If you pay attention to cybersecurity news stories, it can sometimes seem that there are a bewildering variety of attacks that you need to defend against. While this is partly true, many attacks fall into a few known categories. Several methodologies have been developed to try to systematically identify threats to software systems, and we can use these to identify the kinds of threats that might befall your API. One very popular methodology is known by the acronym *STRIDE*, which stands for:

- **S**poofing – pretending to be somebody else
- **T**ampering – altering data, messages, or settings you're not supposed to alter
- **R**epudiation – denying that you did something that you really did do
- **I**nformation disclosure – revealing information that should be kept private
- **D**enial of service – preventing others from accessing information and services
- **E**levation of privilege – gaining access to functionality you're not supposed to have access to